OXYPC INVENTORY LIFECYCLE

OVERVIEW

Key Findings

Security, data-safety and process gaps found while documenting the app, with what to fix first.

Last updated: 25 Oct 2026 · Source: staging branch @ 55ce58a

App Development Team · Bluemonk

Key Findings

Last updated: 25 Oct 2026 · Source: staging branch @ 55ce58a

Writing these documents meant reading the code end to end. Along the way the review found gaps between what the business expects and what the code does today. They are listed here so they can be triaged; each links to the document with the detail and the file references.

Fix first: security

#	Finding	Why it matters	Detail
S1	Uploaded files are served at `/uploads` with no login check (`main.py` mounts `StaticFiles`)	KYC documents, payment proofs, GRN invoices and daily stock files can be downloaded by anyone on the network who knows or guesses a path	Security, Integrations
S2	Page permissions default to "allowed" for custom roles	A new custom role (including the auto-created `sub_admin`) can open every page that is not admin-only until someone restricts it	Security
S3	Default secrets ship in code and seed scripts	DB password, OxyQC agent key, admin and UAT passwords are known defaults unless changed on the server	Security
S4	Permission changes and admin password resets are not written to the audit log	No record of who widened someone's access	Security
S5	CSV exports include prices even when Pricing Visibility is off	Pricing leaks through exports	Permission Matrix

Fix first: data safety

#	Finding	Why it matters	Detail
D1	App, database and backups all sit on one server; `uploads/` is not backed up	One disk or server failure loses data and files	Runbook & DR
D2	Database dumps are made without `--clean` , but the restore script expects to replace tables; no test restore is on record	A restore may fail when it is needed	Runbook & DR
D3	No recovery targets (RPO / RTO) are set	Nobody has agreed how much data loss or downtime is acceptable	NFRs

Process rules the code does not enforce

#	Finding	Detail
P1	A tag can be sold from any stage, not only Ready for Sale. This is deliberate (director's decision, 19 Oct 2026, `services/control_engine.py::validate_sale_allowed`); only blocked tags are refused. Confirm it is still wanted, as the Sales role is described as selling Ready for Sale stock	State Machine
P2	Several stage moves accept any signed-in user and do not check the tag's current stage (L1/L2 Mark Complete, Stress Test fail/complete, Back to Inventory)	State Machine

#	Finding	Detail
P3	The three lists of stages and allowed moves in the code disagree with each other	State Machine, Data Model
P4	Grades differ by screen: Final QC offers A/B/C, the device model A–E plus scrap, CRM A/B/C/D/Mix/As-Is/Scrap	PRD-03
P5	The `returned` stage is never used; a return moves the tag straight to Stock In	State Machine

Roles that do not exist in the code yet

Production Manager, Final QC Inspector, Accounts and TRC Manager have no built-in role. Production work runs under `inventory_manager`, and the Accounts pages refuse a custom Accounts role because `routers/accounts.py` checks a fixed list (`FINANCE_ROLES`). Fifteen templates still check role names directly instead of using `role_allowed()`. See Permission Matrix.

Features expected but not built

#	Expected	Today	Detail
F1	E-way bill generation	Only e-way bill numbers/files for goods coming in are stored	PRD-04, Integrations
F2	GST invoice generation	A printed HTML tax invoice, one tag per invoice, HSN fixed at 8471, GST in floating point, free-text invoice number	PRD-04
F3	Rentals	No code found	Roadmap
F4	Staging server	Auto-deploy pushes `main` straight to production	Deployment
F5	Automated test run	172 test files, no CI job runs them	NFRs

Housekeeping

- `docs/schema.dbml` (29 Apr 2026) is missing 58 of the 147 tables in `models/`; the approved diagram was never saved back. Data Model
- WhatsApp was removed, but `services/care_service.py` still calls it, so Care offer sends fail. Integrations
- `.github/workflows/deploy.yml` still restarts the pre-Docker service. Deployment
- Dashboard: "Revenue This Month" ignores the overrides "Profit This Month" uses; "Active lots" counts trashed lots; the P&L date filter changes nothing on screen. KPI Definitions
- The `CLAUDE.md` note on `is_trashed` is out of date: the columns are now NOT NULL. ADRs